

GARIL AI

Security Assurance Summary

Governed AI for Research, Instruction and Learning

Document type	Security assurance summary for universities
Assessment nature	Defensive security audit & hardening review
Assessment period	September – October 2026
Scope	Web application, API, authentication, data isolation, AI surfaces
Prepared for	Partner universities and institutional stakeholders
Classification	Confidential — for authorised institutional use

Assurance statement

GARIL AI has undergone a defensive security audit. Critical and high-priority findings were remediated. The platform is configured with institutional-grade access control, tenant isolation, and hardened API surfaces suitable for university deployment.

1. Purpose of this document

This summary is prepared for universities evaluating or operating GARIL AI. It confirms that the platform has been subject to a structured defensive security audit and subsequent hardening, and that core controls expected of an institutional research and learning system are in place.

It is written for academic leadership, ICT/security officers, and data-protection stakeholders. It does not disclose internal vulnerability identifiers, attack procedures, or exploitation details.

2. Assurance statement

GARIL AI completed a defensive security audit covering authentication and authorisation, multi-tenant data isolation, API exposure, session handling, AI/cost controls, upload and storage handling, and privacy-sensitive administrative functions.

All Critical findings identified in the audit have been remediated. High-priority hardening items (including open API lockdown, rate limiting, backup privilege restriction, WebSocket authentication, and default admin bootstrap controls) have been implemented. The platform is assessed as suitable for controlled institutional deployment when operated with the production configuration checklist in Section 6.

Critical issues: remediated · High-priority hardening: implemented · Residual work: continuous improvement
Audit outcome (October 2026)
(session-cookie migration, advanced upload scanning, edge CSP).

3. What was assessed

- Identity, authentication, and password lifecycle (including reset flows)
- Role-based and university-scoped authorisation for admin and portal surfaces
- Default-deny protection of APIs (public allowlist only for health, registration, login, and public legal pages)
- Research, chat, and AI endpoints — authentication, feature gates, and usage quotas
- Session and WebSocket security (no tokens in URLs; authenticated channels)
- Cross-tenant isolation expectations for university-scoped administrators
- Administrative backups and privileged data export access
- CORS, security headers, rate limiting, and secrets handling
- Rendering of user/model content (XSS hardening via sanitisation)

4. Security controls in place

Access control & tenancy

- Authenticated sessions required for protected APIs and application features
- University-scoped administration — campus admins cannot manage other institutions
- Platform-wide database backups restricted to super administrators
- Inactive or suspended accounts are rejected on subsequent requests

Data protection & privacy

- Passwords stored using modern salted hashing (scrypt); reset tokens hashed at rest
- Research assets and portal projects filtered by ownership / tenant
- Password-reset responses designed to avoid account enumeration
- Public health endpoint discloses no infrastructure metadata

Application & API hardening

- Default-deny API policy with an explicit public allowlist
- Production CORS restricted to configured institutional origins
- Rate limiting on authentication and AI endpoints to reduce abuse and cost risk
- Security headers via application middleware (including HSTS in production HTTPS)
- HTML and markdown output sanitised before browser rendering

AI governance & cost control

- AI generation and literature search require authenticated users
- University feature flags and student token quotas enforced where applicable
- Per-user chat session isolation to prevent cross-user interference

5. Governance alignment for universities

GARIL AI is designed for institutional research and learning contexts. Security controls support common university expectations around access governance, departmental/university scoping, auditability, and responsible AI use:

- Role-based console access for governance, faculty, compliance, and audit personas
- Audit logging for sensitive administrative actions
- Registration gated to onboarded universities
- Policy acceptance and legal document management for institutional terms
- Retention and deletion request workflows for data-governance processes

6. Production configuration expected of the institution

Security outcomes depend on correct deployment. Partner universities (or their hosting provider) should ensure:

- Strong unique AUTH_SECRET and restricted CORS_ORIGIN allowlist in production
- TLS termination at the institutional reverse proxy / CDN
- Bootstrap administrator credentials rotated and bootstrap mode disabled after first setup
- Application servers not exposed directly to the public internet (proxy-only)
- Object storage buckets kept private; institutional backup encryption and retention as per local policy
- Operational monitoring of authentication failures and AI spend

7. Continuous assurance

Security is an ongoing programme. Following the audit remediation, GARIL AI maintains a continuous-improvement backlog including deeper session-cookie architecture, expanded upload validation, dependency scanning in CI, and periodic re-assessment. A third-party penetration test can be commissioned under a formal rules-of-engagement once the institution requires it.

This document affirms that the platform has undergone defensive security audit and hardening suitable for university partnership. It is not a formal certification (e.g. ISO 27001 or SOC 2), nor a guarantee against all future threats.

8. Contact & document control

Document title: GARIL AI — Institutional Security Assurance Summary

Version: 1.0 · Date: 3 October 2026

Related internal artefact (technical detail, not for general distribution): GARIL-AI-Security-Audit-Report.pdf

For institutional security questionnaires, DPIA inputs, or a walkthrough with university ICT teams, contact the GARIL AI deployment / partnership team.

Summary for institutional stakeholders

GARIL AI has been security-audited and hardened. Critical risks were closed; institutional access control, tenant isolation, and API protections are active. The platform is ready for university deployment under the production controls above.